



Access Controls Policy

HostFi, Inc. — hostfi.ai

Document Owner	Kevin Aramalla, Founder & CEO
Effective Date	February 1, 2026
Last Reviewed	February 17, 2026
Next Review	August 2026
Classification	Internal / Shared with Partners

1. Purpose

This policy defines the access control requirements for HostFi's production systems, customer data, and third-party integrations. The goal is to ensure that access to sensitive resources is authorized, appropriate, and auditable.

2. Scope

This policy applies to:

- Production infrastructure (Vercel, Supabase, DNS, domain registrar)
- Source code repositories (GitHub)
- Third-party service accounts (Stripe, Plaid, Postmark, Google Workspace)
- Customer-facing application access
- All personnel, contractors, or automated systems with access to the above

3. Principles

- **Least Privilege:** Every user and system is granted the minimum access necessary to perform its function.
- **Need to Know:** Access to customer data is restricted to personnel who require it for service delivery or support.
- **Segregation:** Production, preview, and development environments use separate credentials and configurations.
- **Default Deny:** Access is denied by default and explicitly granted when authorized.

4. Customer Application Access Controls

4.1 Authentication

- Users authenticate via email/password (bcrypt hashed) or Google OAuth 2.0 SSO
- Multi-factor authentication (TOTP) is supported via Supabase Auth
- Session tokens are securely generated, transmitted over HTTPS only, and expire after inactivity
- Failed login attempts are rate-limited to prevent brute force attacks

4.2 Authorization — Row Level Security (RLS)

HostFi enforces data isolation at the database level using PostgreSQL Row Level Security policies:

- Every database table containing user data has RLS policies enabled
- All queries are automatically scoped to the authenticated user's ID
- Cross-user data access is architecturally impossible — enforced by the database engine, not application code
- Service role access (for webhooks, background jobs) uses a separate service key with explicit scoping in application logic

4.3 API Endpoint Security

- All API endpoints call `authenticateRequest()` as the first operation
- Unauthenticated requests receive a 401 response before any data access
- User ID from the authenticated session is used for all subsequent database queries
- No API endpoint accepts a user-supplied user ID for data access

4.4 Plan-Based Feature Gating

- Features and resource limits (property count, integrations) are enforced server-side based on the user's subscription plan
- Plan limits are checked on every relevant API call, not just the UI

5. Production Infrastructure Access

System	Access Method	Who Has Access	MFA
Vercel (hosting)	SSO / email login	Founder only	Yes
Supabase (database)	SSO / email login	Founder only	Yes
GitHub (source code)	SSO / SSH key	Founder only	Yes
Stripe (payments)	Email login	Founder only	Yes
Plaid (financial data)	Email login	Founder only	Yes
Google Workspace	Google login	Founder only	Yes
Postmark (email)	Email login	Founder only	Yes
Domain / DNS (Vercel)	Vercel dashboard	Founder only	Yes

6. Third-Party Integration Credentials

- OAuth tokens and API keys for user integrations (Google, Slack, PMS systems) are stored encrypted in the database

- Credentials are never logged, exposed in API responses, or sent to the client-side application
- OAuth 2.0 is used wherever supported — HostFi never stores third-party user passwords
- Users can revoke integration access at any time from their dashboard, which deletes stored credentials

7. Environment Separation

- **Production:** Live environment at hostfi.ai with production database and API keys
- **Preview:** Vercel preview deployments use separate environment variables where applicable
- **Development:** Local development uses separate Supabase project and test API keys
- Production secrets are never used in development or preview environments

8. Secrets Management

- All secrets (API keys, database credentials, OAuth secrets) are stored in Vercel's encrypted environment variable system
- Secrets are never committed to source code or version control
- `.env` files are excluded from git via `.gitignore`
- Secrets are rotated when compromise is suspected or personnel changes occur

9. Access Provisioning & De-provisioning

- New personnel access is granted by the Founder on a need-to-know basis
- Access is revoked immediately upon termination or role change
- All production access is reviewed when team composition changes

- Currently, all production access is held solely by the Founder

10. Monitoring & Auditing

- Authentication events are logged (successful logins, failed attempts)
- API access patterns are logged via Vercel's request logging
- Database access is logged via Supabase's audit capabilities
- Third-party service access is auditable through each provider's admin dashboard

11. Non-Human Access (Service Accounts & Tokens)

- Webhook endpoints authenticate via OAuth tokens or Basic Auth credentials specific to each integration
- The Supabase service role key is used only for server-side operations (webhooks, background sync) and is never exposed to the client
- TLS certificates are used for all machine-to-machine communication
- CI/CD deployments are authenticated through Vercel's GitHub integration with scoped permissions

12. Policy Review

This policy is reviewed semi-annually, upon significant infrastructure changes, or when new team members are onboarded. Updates are approved by the document owner.